

1. 第二次作业第一题

分析 1 比特的明文或密文错误对密码算法的不同模式（5 种）下的加密结果及解密结果的影响。

ECB: 因为每个块是单独加密和解密的, 所以 1 比特的明文或密文错误只会影响该比特所对应块的整块加密或解密的正确性。

CBC: 加密的时候, 1 比特的明文错误会使得这一个块及之后的块的加密结果都发生错误, 因为每一个分组要先和前一个分组加密后的数据进行了异或运算再进行加密, 影响会传递。解密的时候, 1 比特的密文错误只会使得该密文所对应块整块和下一个密文块的对对应位 1bit 解密出错, 因为解密是密文块解密后再和前一个解密前的密文块异或运算得到结果。

CFB: 加密的时候, 前一个块明文的加密结果会影响当前密钥流的产生, 和自同步流密码相似, 从而影响加密结果, 因此 1 比特的明文错误会使得该块对应位 1bit 及之后部分块的整块加密结果都与明文没有错误进行加密的结果不同; 解密的时候, 前一个密文块会影响当前块的密钥流的生成, 所以 1 比特的密文错误也会使得该块对应位 1bit 及之后部分块的整块都解密出错, 直到错误被移出密钥流生成中的内部缓存器。

OFB: 不论是加密还是解密, 密钥流的生成都和当前明文块或密文块无关, 只和前一个块产生的密钥流有关, 和同步流密码类似, 因此 1 比特的明文或密文错误只会使得该块对应位 1bit 的加密或解密结果都出错。

CTR: 不论是加密还是解密, 密钥的生成都只和 K、计数器有关, 因此 1 比特的明文或密文错误只会使得当前块对应位 1bit 的加密或解密错误。

2. 第五次作业第三题

分析 A5 算法中 F_n 的作用, 并计算如果一直保持通话, 多长时间需要重新鉴权。

A5/1 算法就是一个密钥流生成器, 其生成密钥与明（或密文）进行异或运算, 从而实现加密（或解密）功能。其中 K_c 为 64 比特的密钥, F_n 为 22bit 的帧号。

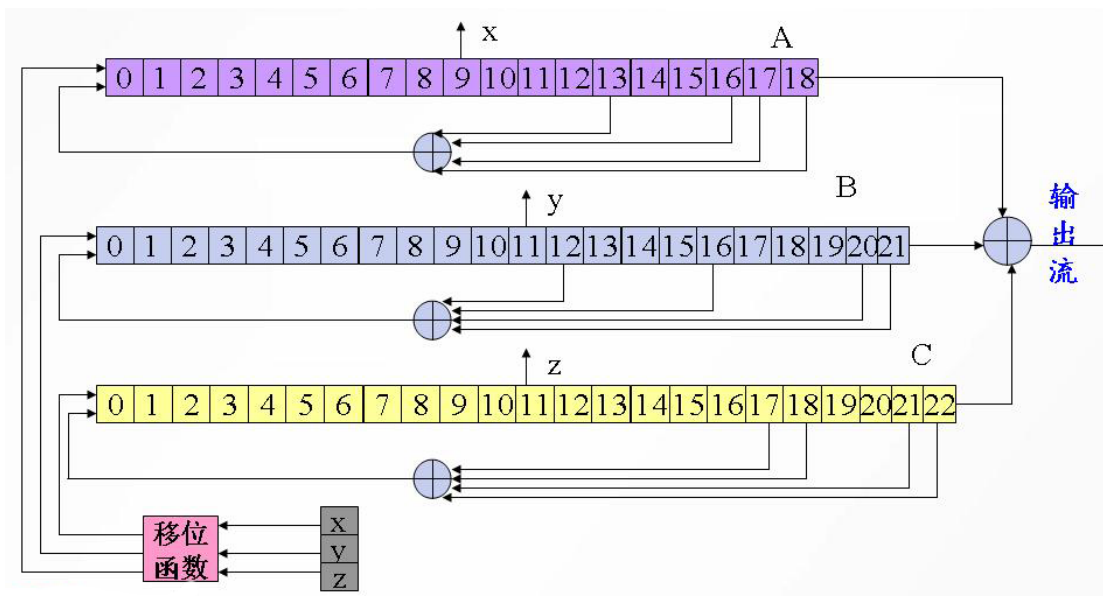
一次通话使用一个会话密钥, 对每帧使用不同的帧密钥。

会话密钥: 基站产生的一个 64bit 的随机数 K 。

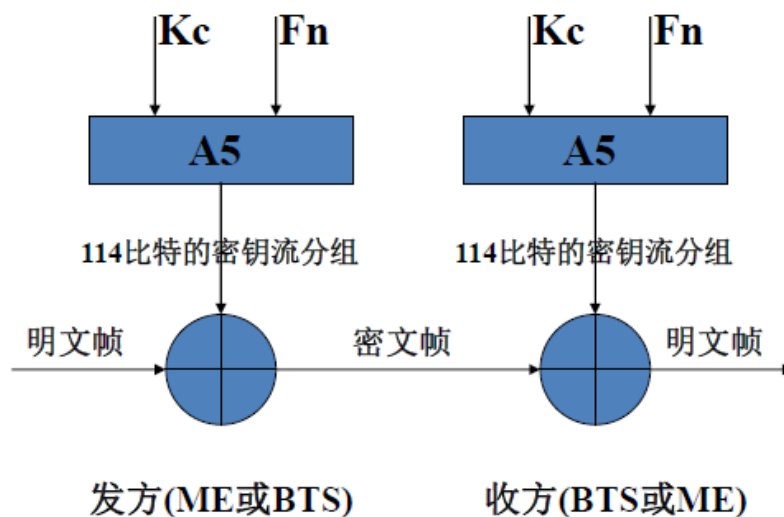
帧会话密钥: 帧序号 F_n , 不同的明文数据按顺序编号, 长度为 22bit。

答案 1: 在计算重新鉴权的时间之前, 我们需要首先了解一直保持通话的情况下发生怎样的情况才会重新鉴权。用户使用 GSM 系统进行通话是通过空中接口采用无线电波的形式完成传输的。GSM 空中接口的物理通道以帧为单位, 一帧的长度为 4.615ms, 包含了 8 个时隙每个 0.577ms。同时, GSM 空中接口采用 TDMA 的多址接入方式, 每个 TDMA 帧都有帧号 F_n , 以 2715648 为周期循环编号。当一个周期完成循环后 TDMA 的帧号将会发生和之前重复的情况, 因此为了保证密钥的唯一性需要重新鉴权产生新的会话密钥 K_c , 这样便可以保证 A5 算法生成密钥的唯一性。因此, 需要鉴权的时间即为 TDMA 帧号的循环时间, 为一个超帧(包含 2715648 个 TDMA 基本帧)的时间。我们自下而上进行计算, 在 TDMA 的接入方式中一个复帧由 26 或 51 个 TDMA 基本帧组成, 一个超帧为 51 或 26 个复帧组成。因此, 一个超帧的时间为 $4.615\text{ms} \times 51 \times 26 \approx 6119.5\text{ms}$

$\approx 6.12s$ 。而一个超高帧由 2048 个超帧组成，因此一个超高帧的时间为 $6.12s \times 2048 = 12533.76s$ 。因此如果一直保持通话，经过 12533.76s 需要重新鉴权，即 3 小时 28 分 53 秒 760 毫秒

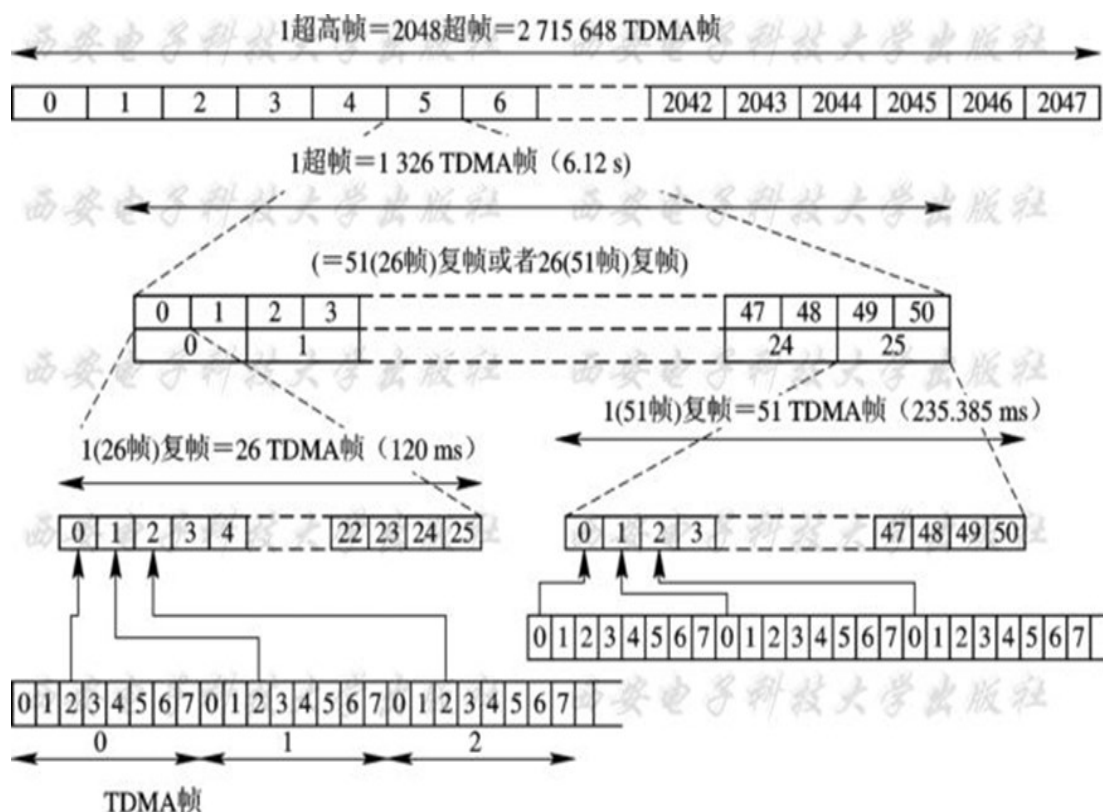


答案 2:



- (1) 以上加密算法将数据划分为每一帧来进行加密，明文帧与 114 比特的密钥流分组异或生成密文帧，密文帧与 114 比特的密钥流分组异或产生明文帧，该 114 比特的密钥流分组即为双方进行通信的会话密钥，Kc 为 64 比特，Fn 为帧号，一共 22 比特，会话密钥由 Kc 和 Fn 通过 A5 算法产生密钥流(会话密钥)，会话密钥再将数据帧进行加(解)密，因此 Fn 的作用为生成会话密钥，保证加解密的同步进行。
- (2) 帧号为 22 比特，也就是说每一帧与 Kc 在 A5 算法的作用下只能产生 2^{22} 比特不同的会话密钥，当已生成 2^{22} 比特会话密钥后，再使用该帧与之前的 Kc 就会生成相同的密钥流，此时需要新的 Kc，Kc 通过鉴权产生，因此需要重新鉴权。

GSM 帧的结构如下：



- (1) TDMA 帧 – 每个 TDMA 帧含 8 个时隙, 整个帧时长约为 4.615ms, 每个时隙含 156.25 个码元, 时隙时长为 0.577ms。
- (2) TDMA 复帧 (Multiframe) – 多个 TDMA 帧构成复帧, 其结构有两种: 连续的 26 个 TDMA 帧构成的复帧, 称为 26 复帧, 周期为 120ms, 用于业务信道和随路控制信道 (TCH 与 SACCH/FACCH)。连续的 51 个 TDMA 帧构成的复帧, 称为 51 复帧, 用于控制信道 (CCH), 周期为 $3060/13 \approx 235.385\text{ms}$ 。
- (3) TDMA 超帧 (Superframe) – 多个连续的 TDMA 复帧构成超帧, 它是一个连续的 51×26 TDMA 帧, 一个超帧的持续时间为 6.12s。
- (4) TDMA 超高帧 (Hyperframe) 它包括 2048 个超帧, 每个周期包括 2715648 个 TDMA 帧。鉴权间隔时间即为 TDMA 超高帧的周期, 即为 $2048 \times 6.12\text{s} = 12533.76\text{s} = 3\text{h}28\text{min}53\text{s}760\text{ms}$, 鉴权时间间隔为 3h28min53s760ms。

3. 第七次作业第二题

描述 WCDMA 系统中的 AKA 协议, 给出其安全目标, 并分析其正确性

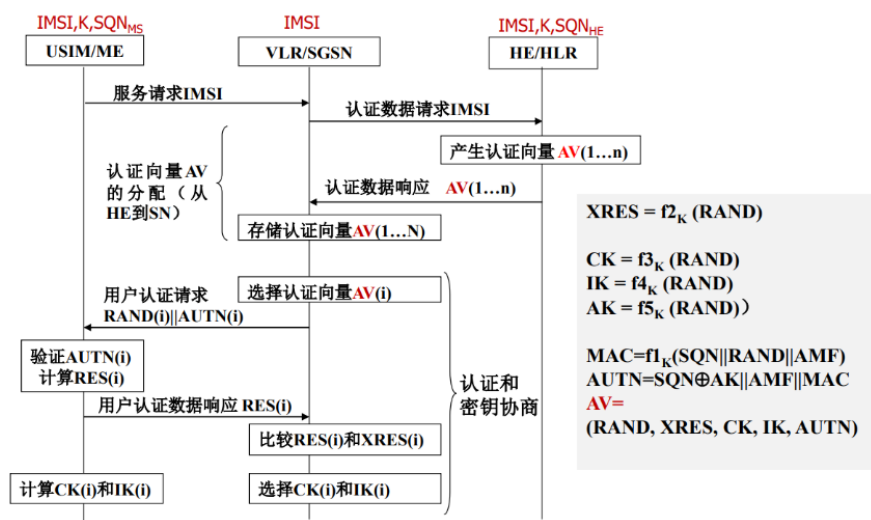
AKA 协议描述:

AKA 全称是第三代移动通讯网络的认证与密钥协商协议, 是国际移动通信组织 3GPP(The Third Generation Partnership Project) 在研究 2G 安全脆弱性的基础上, 针对 3G 接入域安全需求提出的安全规范。AKA 使用挑战应答机制, 完成用户和网络间的身份认证, 同时基于身份认证对通信加密密钥进行协商。通过认证和加密手段更好的预防攻击行为, 保护移动通

信网络资源的安全。

其流程（及图）如下：

1. 用户终端发起认证请求。
2. 服务网络检索本地是否存储该终端对应的未使用的认证向量，如果有则直接执行第 4 步；否则服务网络向归属网络发起认证请求，并传输相关身份信息。
3. 在归属服务器端的认证中心一次性产生组认证向量，发送认证向量组给服务网络。
4. 服务网络选择第 i 组未使用的认证向量，并发送认证向量中的 $RAND(i)$ 和 $AUTN(i)$ 分量给用户终端。
5. 用户终端验证 $AUTN$ ，如果验证不通过则终止认证，否则计算 $RES(i)$ 、 $CK(i)$ 和 $IK(i)$ 然后将 $RES(i)$ 发送给服务网络。
6. 服务网络验证和值是否一致，不一致则不允许该终端接入，否则允许接入。



安全目标：

完成网络与用户的双向认证；

生成加密密钥(CK)和完整性密钥(IK)，保障后续交互的机密性和完整性；

确保 CK 和 IK 的新鲜性，以前没有使用过。

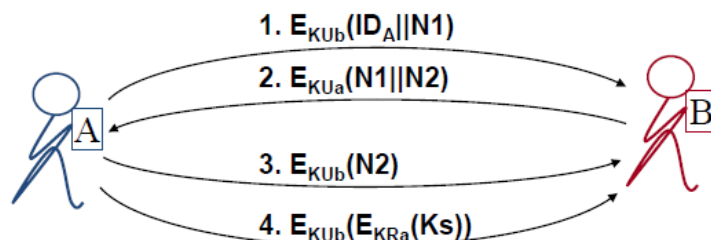
正确性分析：

双向认证完成后提供加密密钥和完整性密钥，防止假基站攻击；密钥的分发没有在空中信道上传输，AV 在固定网内的传输也由网络域安全提供保障；密钥的新鲜性由新的随机数提供，防止重放攻击；对有可能暴露用户位置信息和身份信息的 SQN 用 AK 异或，达到隐藏 SQN 的目的；MAC 的新鲜性，SQN 和 RAND 变化，防止重放攻击。

但也仍存在缺陷，如重定向攻击。攻击者可以伪装成虚假基站诱导合法用户捕获虚假基站的无线信道,又可以伪装成虚假 MS 与真实基站进行通信。这样集成了 MS 和基站双重功能的攻击者就可以在合法用户和真实基站间传递消息,把用户的业务重定向到其他网络。

题目： 使用下图中的协议进行会话密钥协商，前三步是否可以抵御中间人攻击，为什么？

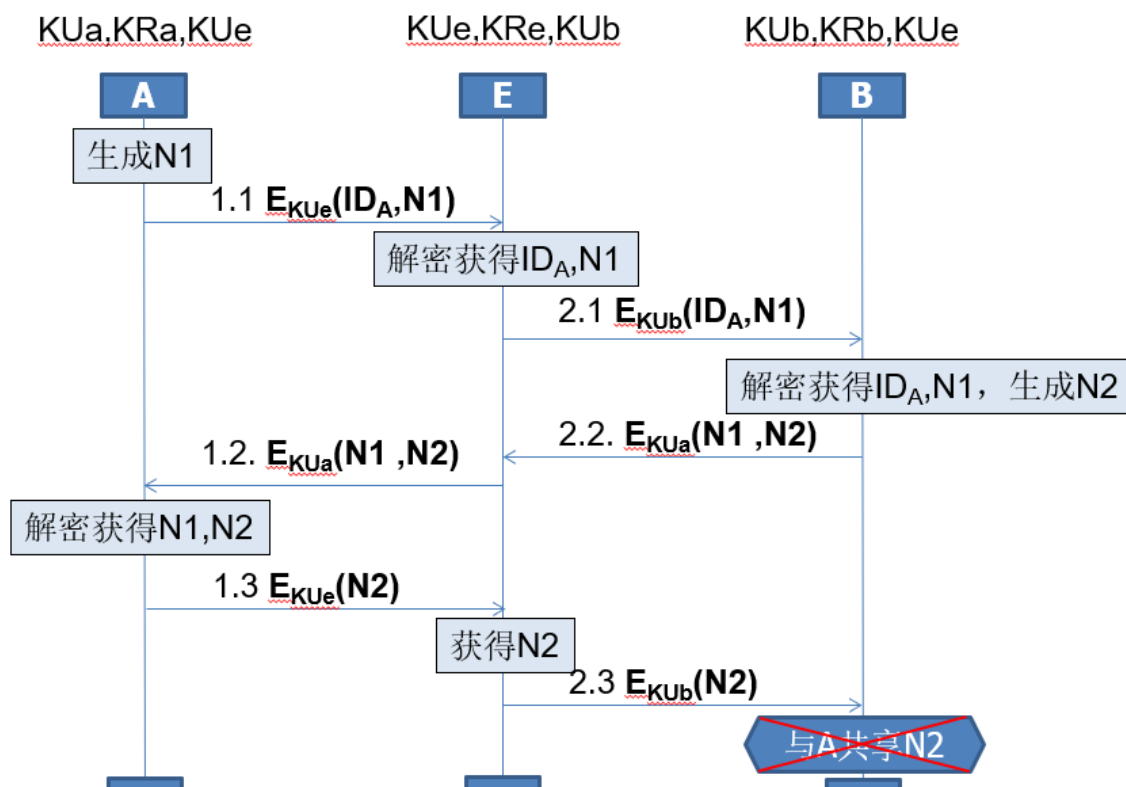
认证的密钥建立协议



假定A和B已经获得了双方的公钥:

1. $A \rightarrow B: E_{K_{Ub}}(ID_A, N1)$
2. $B \rightarrow A: E_{K_{Ua}}(N1, N2)$
3. $A \rightarrow B: E_{K_{Ub}}(N2)$
4. $A \rightarrow B: Y = E_{K_{Ub}}(E_{K_{Ra}}(Ks))$
5. B解密Y获得会话密钥 $Ks = D_{K_{Ua}}(D_{K_{Rb}}(Y))$

答：无法抵御中间人攻击，攻击过程如下：



入侵者 E 通过解密消息 1.1 和消息 1.3 获取发送消息 2.1 和消息 2.3 所需的 N_1 和 N_2 ，消息 1.2 则是消息 2.2 的重放。上述协议运行完，主体 B 认为他与 A 共享秘密 N_2 ，实际上他与 E 共享 N_2 ，E 假冒 A 成功，攻击有效。对于网络系统中任何一个合法用户，只要接收到发给自己的 NS 公钥协议消息 1，就可以发起上述攻击，以欺骗另外一个用户，故 NS 公钥协议是不安全的。

改进的 NS 公钥协议

对于 NS 公钥协议的缺陷，通过在消息 2 中增加了发送者的身份来进行改进，改进的 NS 公钥协议重新进行 SMV 分析，没有发现新的攻击。NS 公钥协议的改进版本为：

消息 1. $A \rightarrow B: E_{K_{Ub}}(N_1, ID_A)$.

消息 2. $B \rightarrow A: E_{K_{Ua}}(N_1, N_2, ID_B)$.

消息 3. $A \rightarrow B: E_{K_{Ub}}(N_2)$.